

Betriebs-Runbook DSGVO (Phase 5)

Praktische Abläufe für den laufenden Betrieb der Lebensgeschichten-App. Verantwortlicher:

Lebenswerk.AI GmbH, Seegebiet Mansfelder Land (GF Prof. Dr. med. Tobias D. Gantner). Stand: 2026-08-02.

Zuständige Aufsichtsbehörde (Unternehmenssitz Seegebiet Mansfelder Land, Sachsen-Anhalt):
Landesbeauftragter für den Datenschutz Sachsen-Anhalt, Leiterstraße 9, 39104 Magdeburg.
Melde-/Kontaktweg vorab verifizieren und hier eintragen:

- Online-Meldeformular: `_[eintragen]_`
- Telefon/E-Mail: `_[eintragen]_`

Zuschnitt auf die valuvita GmbH. Im Auftrag der valuvita GmbH wird ausschließlich die Produktkategorie **Lebenswerk** eingesetzt: Die erzählende Person berichtet ihr eigenes Leben und erhält dafür einen eigenen Zugang. Die Anwendung beherrscht weitere Anlässe — Gedenkbuch, Geburtstag, Jubiläum, Abschied, Geburt, Mutmachbuch, Anamnesebogen —, die hier **nicht beauftragt** und deshalb aus dieser Fassung entfernt sind. Maßgeblich für das Auftragsverhältnis ist diese Fassung.

1. Data-Breach-Prozess (Art. 33 / 34 DSGVO)

Eine „Verletzung des Schutzes personenbezogener Daten“ ist jede Vernichtung, Verlust, Veränderung oder unbefugte Offenlegung von / unbefugter Zugang zu Daten — z. B. Datenleck, Hack, fehlgeleitete Daten, Ransomware, verlorenes Gerät mit Zugriff, kompromittierter Admin-Account.

Die 72-Stunden-Frist (Art. 33) läuft ab Kenntnisnahme. Lieber früh und unvollständig melden als zu spät.

Sofortmaßnahmen (Stunde 0–4) — Eindämmen

1. **Vorfall festhalten:** Wer hat wann was bemerkt? (Zeitstempel notieren.)
2. **Eindämmen:** betroffene Zugänge sperren. Konkret möglich:
 - `ADMIN_TOKEN_SECRET` in Vercel neu setzen → invalidiert **alle** Admin-Sessions.
 - Verdächtige `app_users` im Admin-Panel löschen/Passwort zurücksetzen.
 - Bei Key-Verdacht: `AZURE_OPENAI_KEY` / `AZURE_SPEECH_KEY` / `AZURE_FLUX_KEY` / `SUPABASE_SERVICE_KEY` beim Anbieter rotieren und in Vercel ersetzen.
3. **Beweise sichern:** Audit-Log (Admin → „Audit-Log“) und Vercel-/Supabase-Logs sichten und exportieren, bevor sie rotieren.

Bewerten (Stunde 4–24)

1. **Art & Umfang:** Welche Daten? (Hier potenziell Art.-9-Daten: Stimme, Gesundheits-/Todesumstände, ggf. Religion.) Wie viele Betroffene?
2. **Risiko für die Betroffenen** einschätzen (gering / hoch). Bei sensiblen Daten ist „hoch“ der Regelfall.

Melden

1. **An die Aufsichtsbehörde (Art. 33):** binnen **72 h**, außer die Verletzung führt „voraussichtlich nicht zu einem Risiko“. Im Zweifel melden. Inhalt: Art der Verletzung, betroffene Kategorien/Anzahl, wahrscheinliche Folgen, ergriffene Maßnahmen, Kontaktstelle.
2. **An die Betroffenen (Art. 34):** unverzüglich, wenn **hohes Risiko**. In klarer Sprache: was ist passiert, mögliche Folgen, Empfehlungen, Kontaktstelle. (Kontaktdaten: aus `app_users` / `contributions`.)
3. **Dokumentieren (Art. 33 Abs. 5): jede** Verletzung intern festhalten (auch nicht gemeldete), inkl. Begründung der Melde-Entscheidung → Vorfalregister (siehe unten).

Nach dem Vorfall

1. Ursache beheben, Maßnahme in „Sicherheitskonzept (TOM)“ / dieser Datei nachziehen, ggf. DSFA aktualisieren.

2. Regelmäßige Reviews & Löschläufe

Automatisch (bereits aktiv)

- **Aufbewahrungs-Löschung:** der Anwendung, täglich 03:00 als Container-Apps-Job (`lebenswerk-web-cron-purge`). Löscht die Eingangsdaten **90 Tage nach Ende der Nutzungsdauer** — beim Lebenswerk ohne Anlass-Termin also `created_at` + `LICENSE_MONTHS` (6) + 90 Tage.
- **Housekeeping:** derselbe Lauf entfernt abgelaufene `rate_limits` und `audit_log` -Einträge > 365 Tage.

Manuell – Checkliste

Monatlich

- ☐ Audit-Log sichten (Admin → „Audit-Log“): auffällige Login-Fehlschläge, unerwartete Löschungen, fremde IPs?
- ☐ Löschlauf prüfen: Kommen die fälligen Buchprojekte wie erwartet in der Übersicht an?
- ☐ Aktive `app_users` durchsehen: nur benötigte Konten, korrekte Kategorien.

Quartalsweise

- ☐ Zugriffsrechte/Personal: ausgeschiedene Personen → Konten löschen, Secrets rotieren.
- ☐ Abhängigkeiten aktualisieren (`npm outdated`), bekannte Lücken prüfen.
- ☐ Backup-/Restore von Supabase stichprobenartig verifizieren.

Jährlich

- ☐ DSFA und Verzeichnis der Verarbeitungstätigkeiten (Art. 30) aktualisieren.
- ☐ AVV mit allen aktiven Auftragsverarbeitern (Vercel, Supabase, Microsoft Azure [Azure OpenAI + AI Speech + Foundry/FLUX], Black Forest Labs, GitHub) auf Aktualität prüfen. (Keine US-Anbieter mehr: Anthropic-/OpenAI-Fallbacks am 2026-06-22 entfernt.)
- ☐ „Sicherheitskonzept (TOM)" (TOM) und dieses Runbook überprüfen.

3. Vorfallregister (Art. 33 Abs. 5)

Jeden Vorfall hier oder in einem separaten geschützten Dokument festhalten:

Datum	Entdeckt von	Art des Vorfalls	Betroffene Daten/Anzahl	Risiko	Behörde gemeldet? (Datum)	Betroffene informiert?	Maßnahmen